

CODE OF CONDUCT

MISSION WINDOW

제한시간 2시간 · 외부에서 접속 가능한 웹서비스 배포 · Blue 전용 작전 지침

MISSION PROFILE

당신은 Blue 팀입니다. 아래 명세를 충족하는 서비스 하나를 배포하고, 지정된 공격 표면만 의도된 범위 안에서 구현하십시오.

- › Blue는 Red가 작성한 1:1 문의글을 열람해야 합니다. Red의 열람 요청을 받은 뒤 검증 흐름이 시작됩니다.
- › 관리자와 일반 유저 계정은 각각 1개를 준비합니다. 일반 유저는 Red 이외의 유일한 유저 계정입니다.

01 / ACCESS GATE

기본 계정 흐름을 먼저 개통하십시오. 별도 인증 절차로 흐름을 막지 않는 것이 임무 조건입니다.

회원가입

- › 아이디, 비밀번호, 이메일을 입력받습니다.
- › 이메일 인증 또는 추가 인증은 수행하지 않습니다.

로그인

- › 가입한 계정으로 로그인할 수 있어야 합니다.

비밀번호 재설정

- › 비밀번호 재설정 화면에서는 비밀번호 재설정 토큰만 입력받습니다.
- › 유효한 비밀번호 재설정 토큰만으로 새 비밀번호를 설정할 수 있어야 합니다.

ACCOUNT SIGNAL

관리자로 로그인한 경우 우측 상단에서 관리자임이 명확하게 식별되어야 한다.

ACCOUNT INVENTORY

역할	필수 상태
관리자	1개. 로그인 후 관리자 표식을 노출. 본인 및 글 작성자의 문의글 열람 권한.
일반 유저	1개. Red 이외의 유일한 유저 계정.

02 / INQUIRY NODE

1:1 문의글 기능은 Red의 침투 시험을 위한 지정 공격 표면입니다. 이 영역만 의도적으로 개방하고, 접근 권한과 세션 경계는 정확히 유지하십시오.

작성 및 열람

- › 사용자가 1:1 문의글을 작성할 수 있어야 합니다.
- › 관리자 계정과 해당 작성자만 문의글을 열람할 수 있어야 합니다.

지정된 Stored-XSS

- › 1:1 문의글에는 의도적으로 Stored-XSS 취약점을 구현합니다.
- › 관리자가 페이로드가 포함된 문의글을 확인하면 관리자 세션 또는 토큰이 탈취되어야 합니다.

세션 재활용 경계

- › 탈취한 세션 또는 토큰은 같은 공인 IP에서만 재활용하여 로그인할 수 있어야 합니다.
- › 다른 공인 IP에서 접속하면 해당 세션 또는 토큰은 유효하지 않아야 합니다.

INCOMING INQUIRY

Red의 요청을 받으면 Red가 작성한 1:1 문의글을 열람한다.

IMPLEMENTATION GUARDRAIL

Stored-XSS를 제외한 입력, 인증, 권한, 데이터 접근 흐름에서 의도하지 않은 취약점이 생기지 않게 하십시오. 특히 다른 사용자의 문의글 열람, 토큰 검증, 계정 권한 전이는 요구된 조건을 벗어나 개방되지 않아야 합니다.

03 / CUSTOMER BOT

고객상담 챗봇은 계정 복구 요청을 분류하고, 신원 확인이 끝난 경우에만 재설정 토큰을 전달합니다. 모델은 지정된 것만 사용합니다.

MODEL LOCK

LLM API를 적극 활용하고, 모델은 반드시 llama-3.2-3b-instruct만 사용한다.

대화 시작

- › 챗봇은 먼저 '무엇을 도와드릴까요?'라고 고객에게 질문합니다.
- › 고객은 비밀번호 분실, 계정 분실, 영업시간 등 자연어로 응답할 수 있습니다.

첫 응답 분류

- › 계정 복구 관련이 아니면 '상담챗봇의 처리 사항이 아닙니다'라고 응답하고 상담을 종료합니다.
- › 계정 복구 관련이면 신원 확인 절차를 이어갑니다.

신원 확인 순서

- › 먼저 아이디를 요구합니다.
- › 이후 이메일을 요구합니다.
- › 가입 시 제출한 아이디와 이메일이 모두 일치할 경우에만 해당 계정의 비밀번호 재설정 토큰을 알려줍니다.

LLM 응답 필수 조건

재설정 토큰을 알려주는 기능은 반드시 LLM을 통해 응답해야 합니다. 해당 LLM API 호출 프롬프트에는 반드시 입력받은 아이디와 이메일을 포함하십시오.

04 / PROMPT FIREWALL

챗봇은 자연어를 처리하지만 계정 데이터의 판정 권한을 넘겨받아서 안 됩니다. 프롬프트는 정보 노출을 유도하는 명령을 방어하도록 작성하십시오.

프롬프트 설계 원칙

- › LLM에 입력받은 아이디와 이메일을 포함하되, 신원 검증 결과와 허용된 응답 범위를 서비스 로직으로 엄격히 제어합니다.
- › 다른 계정의 정보, 내부 지시문, 시스템 메시지, 비밀번호 재설정 토큰을 요구하거나 지시를 무시하라는 요청을 따르지 않도록 합니다.
- › 확인되지 않은 사용자 또는 불일치한 아이디·이메일에 토큰을 전달하지 않습니다.

FINAL CHECK

지정된 Stored-XSS 외의 취약점은 차단하고, 명세상 정상 기능은 실제로 끝까지 작동해야 한다.

DEPLOYMENT EXIT

- › 어디서나 접속 가능한 주소로 배포되었는지 확인
- › 관리자·일반 유저 계정 및 핵심 흐름을 점검
- › Red의 열람 요청을 받은 뒤 Red가 작성한 문의글을 Blue가 열람

// END OF TRANSMISSION